

Módulo 7: Ética, privacidad y legislación aplicada a la IA

7.1.1 Sesgos y discriminación: de dónde salen y cómo se ven

Referencia

- **Módulo:** 7. Ética, privacidad y legislación aplicada a la IA
- **Apartado:** 7.1. Ética en la IA: Sesgos algorítmicos, discriminación, transparencia, explicabilidad (XAI)
- **Ficha:** 7.1.1 Sesgos y discriminación: de dónde salen y cómo se ven

Palabras clave

sesgos en IA, discriminación algorítmica, equidad en modelos, variables proxy, datos de entrenamiento, sesgo de muestreo, sesgo histórico, sesgo de medición, sesgo de etiqueta, sesgo en clasificación, impacto en empresa, auditoría de sesgo, mitigación de sesgos

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Explicar qué es un **sesgo** en IA y por qué no es solo “un fallo técnico”, sino un riesgo real para personas y empresas.
2. Identificar **de dónde salen** los sesgos: datos, etiquetas, diseño del objetivo (lo que optimiza el sistema), y contexto de uso.
3. Reconocer **cómo se ven** los sesgos en resultados reales (señales prácticas) y cómo pueden convertirse en **discriminación**.
4. Entender el papel de las **variables proxy** (variables “sustitutas”) en la discriminación algorítmica .
5. Proponer controles básicos sin programar: preguntas de revisión, pruebas “caso espejo”, límites de automatización y supervisión humana.

Síntesis

Los sistemas de IA pueden producir resultados injustos aunque nadie lo pretenda: porque aprenden de datos históricos, de mediciones imperfectas o porque optimizan un objetivo que no captura “justicia” sino eficiencia. Un sesgo se convierte en discriminación cuando afecta de forma sistemática a ciertos grupos o perfiles, limitando oportunidades o generando trato desigual. Para trabajar profesionalmente con IA en empresa hay que saber detectar sesgos, entender variables proxy (atributos que “representan” indirectamente otros más sensibles) y diseñar controles: pruebas, revisión humana en decisiones de alto impacto y métricas de equidad.

Contenido principal

1) Aclaración clave: “sesgo” no siempre significa “mala intención”

En conversaciones sobre IA se confunde con frecuencia “sesgo” con “intención discriminatoria”. En la práctica, la mayoría de sesgos que veremos en empresa son **no intencionales**: aparecen porque el sistema aprende patrones del pasado o porque los datos reflejan cómo funciona el mundo real (con desigualdades previas). Eso no los hace menos peligrosos. De hecho, el riesgo principal es que un sistema sesgado puede:

- escalar una desigualdad (aplicarla a miles de casos),
- hacerlo de forma silenciosa (sin que nadie lo note al principio),
- y dar apariencia de “objetividad” (“lo ha dicho el algoritmo”).

Idea para el alumno: la IA no es neutral “por defecto”. La neutralidad se construye con diseño, datos y control.

2) Qué es un sesgo en IA (definición operativa)

Un **sesgo** es un patrón sistemático de error o desequilibrio en cómo el sistema trata casos distintos. No es un error aleatorio (“a veces falla”), sino una **tendencia** a:

- favorecer,
 - perjudicar,
 - o representar mal
- a ciertos perfiles, situaciones o subgrupos.

En términos empresariales, se puede traducir como:

- un sistema que “recomienda menos” a ciertos perfiles,
- un filtro que “rechaza más” a ciertos candidatos,
- un scoring que “penaliza” a ciertos barrios,
- un detector que “marca como fraude” más a ciertas tipologías de cliente.

Importante: un sesgo puede aparecer aunque el sistema tenga buena precisión media. Puedes tener un 90% global y, aun así, fallar mucho más en un subgrupo.

3) Qué es discriminación algorítmica (y por qué aparece aunque no uses datos sensibles)

Hablamos de **discriminación algorítmica** cuando el resultado produce un trato desigual injustificado. La discriminación puede ser directa (si se usa un atributo sensible explícito) o indirecta, a través de **variables proxy**.

3.1 Variables proxy: el concepto que más problemas causa

Una **variable proxy** es una variable aparentemente “neutral” que, en la práctica, está muy correlacionada con atributos sensibles (origen, nivel socioeconómico, etc.). Ejemplos típicos:

- código postal,
- centro educativo,
- historial de empleo,
- tipo de dispositivo o hábitos digitales,
- horarios de conexión,

- incluso “estilo de escritura” o idioma.

El sistema puede “aprender” que esas variables predicen un resultado (por ejemplo, impago), pero al hacerlo puede acabar discriminando indirectamente.

Ejemplo fácil de entender: si un modelo usa el código postal para predecir “riesgo”, puede penalizar sistemáticamente barrios con menor renta. Aunque el modelo no vea la renta, el código postal funciona como proxy.

Consejo práctico: cuando diseñes un sistema, pregúntate:

“¿Esta variable puede estar representando otra cosa sensible sin decirlo?”

4) De dónde salen los sesgos: mapa completo de causas

Los sesgos no salen solo “del modelo”. Suelen aparecer en 4 capas:

4.1 Sesgo en los datos (qué ejemplos ve el sistema)

- **Sesgo de muestreo:** el dataset no representa a toda la población (hay grupos infrarrepresentados).
- **Sesgo histórico:** los datos reflejan decisiones humanas pasadas (con desigualdades previas).
- **Sesgo de supervivencia:** solo ves los casos que “sobreviven” al proceso (por ejemplo, solo los que llegan a entrevista).
- **Sesgo de cobertura:** ciertos contextos no aparecen (por ejemplo, datos de una región, pero no de otra).

Ejemplo empresarial típico: si un sistema de selección se entrena con “empleados que tuvieron éxito” de una empresa donde históricamente ciertos perfiles no llegaron, el modelo puede aprender esa historia como “norma”.

4.2 Sesgo de medición (cómo se capturan las variables)

Aunque el concepto sea correcto, la medición puede ser mala:

- una variable de “rendimiento” medida por ventas puede penalizar a quien trabajó en territorios peores,
- un “nivel de calidad” medido por tickets puede reflejar que ciertos clientes se quejan más, no que el agente sea peor.

Regla: si mides mal, optimizas mal.

4.3 Sesgo de etiqueta (cómo se define el “resultado correcto”)

En ML, las **etiquetas** son la “respuesta” que el modelo aprende a predecir (por ejemplo, “apto/no apto”, “fraude/no fraude”). Si las etiquetas se basan en decisiones humanas imperfectas, el modelo aprende esas imperfecciones.

Ejemplo:

- Etiqueta “buen candidato” = “fue contratado”.
Pero esa decisión puede haber estado sesgada por entrevistas, redes de contacto, etc.

4.4 Sesgo por objetivo (lo que optimiza el sistema)

Los modelos optimizan un objetivo: precisión, reducción de costes, detección temprana...

Si el objetivo no incluye equidad o coste del error, puede “ganar” en eficiencia y perder en justicia.

Ejemplo:

- Un detector de fraude puede reducir falsos negativos, pero aumentar falsos positivos en un subgrupo.
Si el coste humano del falso positivo (bloqueo injusto) es alto, el objetivo está mal planteado.

5) Cómo se ven los sesgos en la práctica: señales y síntomas

Un alumno debe aprender a detectar sesgo sin ser data scientist. Señales típicas:

1. Diferencias sistemáticas por subgrupo

- tasas de rechazo más altas en un segmento,
- peores recomendaciones en una audiencia,
- más “alertas” en un perfil.

2. Errores concentrados

El sistema falla especialmente en:

- nombres extranjeros,
- acentos,
- mujeres en ciertos roles,
- edades extremas,
- contextos menos representados en el dataset.

3. Decisiones “raras” pero repetidas

El sistema no solo se equivoca: se equivoca siempre en el mismo sentido.

4. Inexplicabilidad operativa

El equipo no puede explicar por qué “siempre rechaza” ciertos casos.

Recomendación de aprendizaje: hay que mirar métricas “por segmento”, no solo globales.

6) El coste real del sesgo para una empresa (por qué importa incluso si no eres “sector regulado”)

A nivel empresarial, sesgo y discriminación generan:

- **riesgo legal** (discriminación, protección de datos, derechos),
- **riesgo reputacional** (casos virales, pérdida de confianza),
- **riesgo operativo** (decisiones equivocadas, pérdida de talento, pérdida de clientes),
- **riesgo económico** (coste de reclamaciones, rotación, campañas fallidas).

Y un punto crítico: un sesgo puede destruir el propósito del sistema. Por ejemplo:

- un sistema de selección que “filtra mal” reduce diversidad de talento y calidad real,
- un scoring sesgado reduce conversiones (rechazas clientes que sí eran buenos),
- una personalización sesgada empeora experiencia.

Idea clave: sesgo no es solo “ética”; es también “calidad y negocio”.

7) Controles básicos para detectar y mitigar sesgos (sin programar)

Aquí tienes un “kit mínimo” que cualquier equipo puede aplicar.

7.1 Preguntas de revisión antes de desplegar

- ¿Qué decisión toma el sistema y qué impacto tiene?
- ¿A quién puede perjudicar si se equivoca?
- ¿Qué variables podrían ser proxy de atributos sensibles?
- ¿Qué grupos están infrarrepresentados?
- ¿Qué hará el sistema cuando tenga baja confianza? (derivar a humano)

7.2 Pruebas “caso espejo” (muy didácticas)

Crea pares de casos idénticos cambiando solo un elemento que **no debería** afectar (por ejemplo, nombre o código postal). Si el resultado cambia sistemáticamente, hay señal de sesgo.

Ejemplos de caso espejo:

- CV con mismas competencias y cambia “nombre”,
- solicitud de crédito idéntica y cambia “zona”,
- ticket idéntico y cambia “idioma/registro”.

7.3 Human-in-the-loop (supervisión humana)

En decisiones de alto impacto:

- el sistema no debe decidir solo,
- debe proponer y justificar,
- y un humano revisa y firma.

Esto reduce riesgo y permite aprender.

7.4 Límites explícitos del sistema

El sistema debe tener límites:

- “no tomo decisiones finales”,
- “no uso datos sensibles” (y cuidado con proxies),
- “derivo cuando no hay evidencia”.

7.5 Auditoría simple por segmentos

Incluso sin estadística avanzada, se puede revisar mensualmente:

- % aceptados/rechazados por segmento,
- % errores o reclamaciones por segmento,
- diferencias llamativas que requieren investigación.

8) Qué hacer si detectas sesgo: respuesta operativa (pasos)

1. **Detener o limitar la automatización** en esa decisión (modo seguro).
2. **Identificar dónde está el problema:** datos, medición, etiqueta, objetivo.
3. **Revisar variables proxy** y eliminar o controlar las más problemáticas.
4. **Ajustar el proceso:** más revisión humana, reglas más conservadoras, mejor información al usuario.
5. **Documentar y medir:** qué cambió, qué métrica mejora, qué riesgo queda.

9) Qué debes poder explicar como alumno (en lenguaje no técnico)

Al final de esta ficha, un alumno debería poder:

- explicar sesgo con ejemplos,
- explicar proxy con ejemplos,
- y describir un plan mínimo de control en una empresa pequeña.

Eso es empleabilidad: convertir un concepto complejo en decisiones y controles aplicables.

Relación de ideas clave

- Sesgo $\neq$ mala intención; puede ser resultado de datos y objetivos.
- Discriminación puede ser indirecta por **variables proxy**.
- Las causas típicas: datos, medición, etiquetas y objetivo del sistema.
- Se detecta mirando métricas por segmentos y con pruebas “caso espejo”.
- Controles mínimos: revisión humana en alto impacto, límites, auditoría y trazabilidad.
- Sesgo es un riesgo ético y también un riesgo de negocio.

Más información en ChatGPT

- “Explicame con ejemplos prácticos (empresa) qué son variables proxy y cómo pueden causar discriminación algorítmica. Incluye 5 señales para detectarlas.”
- “Diseña un protocolo de revisión humana (human-in-the-loop) para un sistema que decide [selección/credit scoring/detección fraude], incluyendo cuándo derivar y qué registrar.”
- “Propón 10 pruebas ‘caso espejo’ para detectar sesgos en un sistema de [caso de uso], y qué resultados indicarían riesgo.”

7.1.2 Discriminación algorítmica y variables proxy

Referencia

- **Módulo:** 7. Ética, privacidad y legislación aplicada a la IA
- **Apartado:** 7.1 Ética en la IA
- **Ficha:** 7.1.2 Discriminación algorítmica y variables proxy

Palabras clave

discriminación algorítmica, variables proxy, discriminación indirecta, equidad en IA, correlación vs causalidad, sesgo de selección, scoring, modelos de riesgo, decisiones automatizadas, fairness metrics, auditoría por segmentos, control humano, políticas de no discriminación

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Diferenciar **sesgo**, **discriminación** y **discriminación algorítmica** en términos operativos (qué se ve y qué implica).
2. Explicar qué son las **variables proxy**, por qué aparecen aunque “no uses” datos sensibles y por qué son un riesgo central en empresa.
3. Reconocer **patrones típicos** de discriminación indirecta en casos reales (RRHH, crédito, fraude, marketing, soporte).
4. Diseñar un enfoque mínimo de prevención: **limitación de variables**, pruebas “caso espejo”, auditoría por segmentos, umbrales y revisión humana.
5. Redactar un checklist de preguntas para evaluar un sistema antes de ponerlo en producción (sin programar).

Síntesis

La discriminación algorítmica ocurre cuando un sistema de IA produce resultados sistemáticamente desfavorables para ciertos grupos, incluso sin intención discriminatoria. El riesgo aumenta cuando variables aparentemente “neutrales” actúan como **proxy** (sustitutas) de atributos sensibles: por ejemplo, código postal como proxy de nivel socioeconómico. Esta ficha enseña a entender cómo se produce la discriminación indirecta, cómo detectarla con señales y pruebas prácticas, y cómo diseñar controles realistas en empresa (auditoría por segmentos, límites de automatización, trazabilidad y supervisión humana).

Contenido principal

1) Diferenciar conceptos: sesgo vs discriminación (sin tecnicismos)

- **Sesgo:** patrón sistemático de error o desequilibrio en resultados (no es aleatorio).
- **Discriminación:** trato desigual injustificado que perjudica a personas o grupos.

- **Discriminación algorítmica:** discriminación causada o amplificada por un sistema automatizado (modelo, reglas, scoring, recomendador, etc.).

Una empresa puede tener sesgo “sin darse cuenta” y acabar discriminando “sin querer”.

El problema no es la intención, sino el **impacto** y la **repetición a escala**: un algoritmo puede aplicar el mismo patrón miles de veces, con apariencia de objetividad.

Idea clave para el alumno: en IA, “parece objetivo” no significa “es justo”. Lo justo se diseña, se prueba y se controla.

2) Por qué aparece discriminación aunque no uses “datos sensibles”

Muchos equipos creen que basta con “no incluir género o origen”. Eso reduce el riesgo de discriminación directa, pero **no elimina** la discriminación indirecta.

La razón: los sistemas aprenden correlaciones. Si un dato está correlacionado con un atributo sensible, puede actuar como su sustituto. Aquí entra el concepto central de la ficha.

3) Variables proxy: definición y por qué son tan peligrosas

Una **variable proxy** es una variable que no es sensible “en sí misma”, pero que está fuertemente relacionada con características sensibles o protegidas en la realidad.

Ejemplos típicos (según contexto):

- **Código postal** → puede correlacionar con renta, origen, acceso a educación.
- **Centro educativo** → correlaciona con clase social u oportunidades históricas.
- **Historial laboral** → correlaciona con desigualdades previas (brechas).
- **Patrones de horario** (turnos nocturnos, disponibilidad) → pueden reflejar condiciones socioeconómicas o de cuidados.
- **Idioma / estilo de escritura** → puede correlacionar con origen, acceso a educación.
- **Tipo de dispositivo / calidad de conexión** → puede correlacionar con renta.

Por qué es peligroso: el modelo puede “descubrir” que esa variable mejora la predicción y usarla para optimizar su objetivo (por ejemplo, reducir impagos). Sin controles, eso puede penalizar sistemáticamente a ciertos perfiles aunque nunca se haya usado un dato sensible explícito.

Consejo práctico: cuando veas una variable “muy predictiva”, pregúntate:

“¿Es predictiva porque captura el fenómeno real o porque captura desigualdades históricas?”

4) Discriminación directa vs indirecta (y por qué la indirecta es más frecuente)

- **Directa:** “si es X, entonces Y” usando un atributo sensible. Es más fácil de detectar (y normalmente se evita).
- **Indirecta:** se usa una variable proxy o una combinación de variables que, en la práctica, produce efectos similares a usar el atributo sensible.

En empresa, la discriminación indirecta es más frecuente porque:

- los equipos no se dan cuenta de las correlaciones,

- los datos disponibles “invitan” a usar proxies,
- y el objetivo del modelo (eficiencia) suele ignorar equidad.

5) Dónde aparece más la discriminación algorítmica (casos reales típicos)

5.1 RRHH (selección, movilidad interna)

- Un sistema filtra CVs y “prefiere” trayectorias típicas, penalizando carreras no lineales.
- Proxy habitual: “lagunas” en CV, centro educativo, continuidad laboral.

Riesgo: perder talento y reproducir desigualdades.

5.2 Crédito / scoring / riesgo

- Se decide límite o aceptación por “riesgo”.
- Proxy habitual: código postal, historial de compras, patrón de pagos.

Riesgo: exclusión financiera injusta y riesgo legal.

5.3 Fraude y seguridad

- Modelos que detectan fraude pueden generar falsos positivos concentrados en ciertos perfiles.
- Proxy habitual: comportamiento digital, dispositivo, localización.

Riesgo: bloqueo injusto y daño reputacional (“me han cancelado la cuenta sin motivo”).

5.4 Marketing (segmentación y personalización)

- Algoritmos que muestran ofertas diferentes y “esconden” oportunidades a ciertos perfiles.
- Proxy habitual: comportamiento, dispositivo, ubicación.

Riesgo: discriminación en acceso a ofertas y percepción de injusticia.

5.5 Operaciones / soporte

- Priorización de tickets o asignación de recursos que penaliza ciertos clientes “por patrón”.
- Proxy habitual: tono del mensaje, idioma, historial.

Riesgo: servicio desigual.

6) Señales prácticas de discriminación (qué mirar sin ser data scientist)

1. Diferencias persistentes por segmento

Ej.: tasa de rechazo mucho mayor en un grupo, durante semanas/meses.

2. Concentración de errores

Ej.: un tipo de cliente sufre más falsos positivos (fraude) o más rechazos.

3. Quejas repetidas con patrón

Ej.: “siempre me rechazan” o “a mi entorno le pasa más”.

4. Decisiones difíciles de justificar

Ej.: el equipo no puede explicar por qué esa persona fue rechazada y “solo dice score bajo”.

Recomendación operativa: medir no solo precisión global, sino tasas por segmento (cuando sea legal/posible), y al menos por proxies operativos (canal, zona, tipo de cliente, dispositivo).

7) Prevención práctica: cómo reducir el riesgo sin programar

7.1 Limitar variables (política de variables)

Antes de entrenar o comprar una solución, define:

- variables permitidas,
- variables prohibidas,
- variables “sensibles por proxy” que requieren revisión.

Consejo: una variable puede ser legal, pero riesgosa. La política interna puede ser más estricta que el mínimo legal.

7.2 “Caso espejo” (test didáctico imprescindible)

Diseña pares de casos idénticos cambiando solo un atributo que no debería importar (o un proxy sospechoso):

- mismo perfil, distinto código postal,
- mismo CV, distinto nombre,
- misma solicitud, distinto dispositivo.

Si el resultado cambia sistemáticamente, es señal de discriminación indirecta o proxy.

7.3 Umbrales y revisión humana

En decisiones de alto impacto:

- el sistema **recomienda**,
- no decide automáticamente,
- y se define un umbral claro para derivar a revisión.

Ejemplo:

- si el score está en “zona gris”, revisión humana obligatoria,
- si hay baja confianza o falta evidencia, no automatizar.

7.4 Explicación mínima y derecho a revisión

Aunque el usuario no pida “XAI”, una empresa responsable debe poder:

- explicar criterios generales,
- y ofrecer canal de revisión.

Esto reduce riesgo reputacional y mejora confianza.

8) Checklist final para evaluar un sistema (para aula y empresa)

1. ¿Qué decisión toma y qué impacto tiene?
2. ¿Qué grupos podrían verse perjudicados?
3. ¿Qué variables podrían actuar como proxy?
4. ¿Hay datos representativos o hay huecos?
5. ¿Cómo se definen las etiquetas (qué es “éxito”)?
6. ¿Qué coste tiene un falso positivo y un falso negativo?
7. ¿Hay umbrales y revisión humana?
8. ¿Cómo se audita por segmentos y con qué frecuencia?
9. ¿Qué se documenta y quién es responsable?

Relación de ideas clave

- La discriminación algorítmica suele ser **indirecta**: aparece por variables proxy.
- No usar datos sensibles explícitos **no garantiza** equidad.
- Se detecta con análisis por segmentos y pruebas “caso espejo”.
- Controles mínimos: política de variables, umbrales, revisión humana, auditoría y trazabilidad.
- Es un riesgo ético, legal, reputacional y también de negocio (calidad de decisiones).

Más información en ChatGPT

- “Dame 12 ejemplos de variables proxy en el caso [RRHH / scoring / fraude / marketing] y explica por qué pueden discriminar indirectamente.”
- “Crea un plan de pruebas ‘caso espejo’ para detectar discriminación en un sistema que decide [caso]. Incluye cómo interpretar resultados.”
- “Ayúdame a redactar una política de variables: permitidas, prohibidas y ‘proxy sospechosas’ para un modelo de [caso].”

7.1.3 Transparencia y explicabilidad (XAI): conceptos y límites

Referencia

- **Módulo:** 7. Ética, privacidad y legislación aplicada a la IA
- **Apartado:** 7.1 Ética en la IA
- **Ficha:** 7.1.3 Transparencia y explicabilidad (XAI): conceptos y límites

Palabras clave

transparencia en IA, explicabilidad XAI, interpretabilidad, derecho a explicación, modelos caja negra, evidencia y trazabilidad, umbrales de confianza, razones del modelo, auditoría, documentación modelo, fichas modelo, límites de XAI

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Diferenciar **transparencia, explicabilidad (XAI) e interpretabilidad** en lenguaje práctico.
2. Identificar qué nivel de explicación necesita cada caso según **riesgo e impacto** (no todo requiere lo mismo).
3. Entender los límites reales de XAI: por qué “explicar” no siempre significa “ser correcto” ni “ser justo”.
4. Diseñar un enfoque de explicabilidad aplicable en empresa: trazabilidad, evidencia, umbrales, revisión humana y documentación.
5. Redactar mensajes de transparencia para usuarios (internos/externos): qué hace el sistema, qué no, y cómo reclamar revisión.

Síntesis

La transparencia y la explicabilidad son fundamentales para usar IA con responsabilidad: aumentan confianza, facilitan auditoría y permiten corregir errores. Sin embargo, XAI no es magia: muchas explicaciones son aproximaciones y pueden dar falsa sensación de seguridad. Esta ficha enseña conceptos básicos (qué es transparencia, qué es XAI), cuándo conviene exigir explicaciones (alto impacto), cómo diseñarlas con trazabilidad y evidencia, y cuáles son sus límites (explicaciones “bonitas” pero engañosas, opacidad de LLMs, y riesgo de sobreconfianza).

Contenido principal

1) Transparencia: qué es y qué incluye (más allá de “decir que es IA”)

Transparencia es que una persona pueda entender, de manera razonable:

- que está interactuando con un sistema automatizado,
- qué tipo de tarea hace,
- con qué información trabaja (a alto nivel),
- cuáles son sus límites,

- y qué opciones tiene si no está de acuerdo (revisión, reclamación, humano).

En empresa, transparencia también significa:

- documentar el sistema internamente,
- registrar decisiones,
- y poder responder “qué pasó” ante una incidencia.

Recomendación: transparencia no es un texto legal largo. Es claridad operativa y verificable.

2) Explicabilidad (XAI) e interpretabilidad: diferencias útiles

- **Interpretabilidad:** el modelo es intrínsecamente comprensible (por ejemplo, reglas simples o modelos lineales sencillos).
- **XAI (eXplainable AI):** técnicas para explicar modelos complejos (caja negra) mediante aproximaciones: “qué variables influyeron”, “qué evidencia pesó”, etc.

Ejemplo didáctico:

- Un sistema de reglas (“si falta DNI, no aprobar”) es interpretable.
- Un modelo complejo que usa decenas de señales requiere XAI para dar pistas de por qué decidió.

Consejo: no todos los sistemas necesitan XAI avanzada. A veces, el diseño del proceso (umbral + revisión) es más importante que una explicación sofisticada.

3) Por qué la explicabilidad importa (beneficios reales)

1. **Confianza informada:** usuarios aceptan mejor decisiones si entienden el criterio.
2. **Auditoría:** permite detectar sesgos y errores sistemáticos.
3. **Mejora continua:** si sabes por qué falla, puedes corregir datos, reglas o umbrales.
4. **Gestión de riesgos:** en alto impacto, una explicación mínima + revisión humana reduce daños.

Idea clave: la explicabilidad no solo es ética: es una herramienta de calidad y operación.

4) Niveles de explicación según riesgo (modelo práctico)

No hace falta el mismo nivel de XAI para todo. Un enfoque profesional usa niveles:

Nivel 1 – Transparencia básica (bajo impacto)

- “Este asistente es automático.”
- “No toma decisiones finales.”
- “No compartas datos sensibles.”
- “Si no resuelve, deriva a humano.”

Ej.: bot de FAQ.

Nivel 2 – Explicación de criterios (impacto medio)

- “Priorizamos por urgencia, antigüedad y tipo de incidencia.”
- “Si faltan datos, pedimos información adicional.”

Ej.: triage de tickets.

Nivel 3 – Explicación + evidencia + revisión (alto impacto)

- “Tu solicitud se ha evaluado por estos factores...”

- “Puedes solicitar revisión humana.”
- “Registramos la decisión y su justificación.”

Ej.: RRHH, crédito, acceso a servicios.

Recomendación: cuando el impacto es alto, la explicación debe ir acompañada de **procedimiento de revisión**.

5) Tipos de explicaciones que se usan en la práctica

5.1 Explicación por factores (qué influyó)

“Influyeron principalmente: historial de pagos, estabilidad de ingresos, endeudamiento...”

Riesgo: puede simplificar demasiado y ocultar proxies.

5.2 Explicación por ejemplos (casos similares)

“Casos similares con estas características terminaron en...”

Riesgo: si los casos históricos estaban sesgados, replica sesgo.

5.3 Explicación contrafactual (qué tendría que cambiar)

“Si el ingreso fuera X o la documentación estuviera completa, la decisión podría cambiar.”

Ventaja: útil para el usuario porque indica acción.

5.4 Explicación basada en evidencia documental (muy útil en empresa)

En asistentes que usan base de conocimiento (RAG), la mejor explicabilidad suele ser:

- “Respondo según este documento/política...”
- “Aquí está la fuente.”

Esto reduce inventos y aumenta trazabilidad.

6) Límites reales de XAI (lo que un alumno debe entender para no caer en “falsa seguridad”)

6.1 Explicación $\neq$ verdad

Un sistema puede dar una explicación convincente y aun así estar equivocado. Algunas técnicas de XAI generan “aproximaciones” y no la causa real.

6.2 Explicación $\neq$ justicia

Puedes explicar perfectamente una decisión injusta (“rechazado por código postal”).

Explicar no elimina discriminación: solo la hace visible. Luego hay que corregir.

6.3 Modelos complejos y LLMs

En modelos generativos (LLMs), la explicabilidad es más difícil: muchas veces puedes explicar el proceso (qué fuentes consultó, qué instrucciones siguió), pero no “por qué” eligió una palabra exacta.

Recomendación: en LLMs, la explicabilidad práctica se basa en:

- trazabilidad de fuentes (si hay RAG),
- logs de prompts y versiones,
- y políticas de no inventar + revisión humana.

6.4 Riesgo de “explicación cosmética”

A veces se construyen explicaciones para tranquilizar, no para auditar. Eso es peligroso: aumenta sobreconfianza.

Señal de alarma: explicaciones demasiado genéricas que servirían para cualquier caso (“se evaluaron múltiples factores”).

7) Diseño de explicabilidad aplicable en empresa (sin programar)

Un “kit mínimo” que cualquier organización puede aplicar:

1. **Registro de decisión (log)**
Qué decisión, cuándo, qué versión del sistema, qué datos se usaron (sin datos excesivos), y resultado.
2. **Criterios y umbrales documentados**
Cuándo decide automático, cuándo deriva a humano (zona gris).
3. **Evidencia o fuentes cuando existan**
En políticas y procedimientos: indicar documento y fecha.
4. **Canal de revisión humana**
Cómo reclamar o pedir revisión, y tiempos.
5. **Auditoría periódica**
Revisar decisiones por segmentos y casos de error.

Consejo: muchas veces, un buen diseño de proceso (umbral + revisión + logs) aporta más explicabilidad real que un gráfico complejo.

8) Mensajes de transparencia para usuarios (plantillas)

8.1 Plantilla “usuario externo”

- “Este sistema usa automatización para ayudarte con [tarea].”
- “No toma decisiones finales en [tema sensible] sin revisión.”
- “No compartas datos sensibles.”
- “Si no estás de acuerdo con el resultado, puedes solicitar revisión en [canal].”

8.2 Plantilla “usuario interno”

- “Este asistente recomienda, pero la decisión final es del responsable.”
- “Las recomendaciones se basan en [fuentes: políticas, CRM, tickets].”
- “Si detectas un error o sesgo, registra incidencia en [procedimiento].”

9) Qué debe poder hacer un alumno con XAI (competencia de empleabilidad)

- Explicar a un responsable no técnico qué significa transparencia y por qué importa.
- Identificar cuándo pedir explicabilidad “alta” (alto impacto).
- Diseñar un plan mínimo de trazabilidad y revisión.
- Evitar vender “explicación” como magia: reconocer límites.

Relación de ideas clave

- Transparencia = claridad operativa + opciones de revisión, no solo “aviso legal”.
- Interpretabilidad (simple) ≠ XAI (explicar lo complejo).
- La explicabilidad mejora confianza, auditoría y operación, pero tiene límites.

Programa Superior en Inteligencia Artificial Aplicada a la Empresa

Fichas de contenido

- Explicación no garantiza verdad ni justicia; puede ser cosmética si no hay trazabilidad.
- En empresa, la explicabilidad más útil combina: criterios, umbrales, logs, evidencia y revisión humana.

Más información en ChatGPT

- “Redacta mensajes de transparencia para un sistema de IA que hace [tarea], diferenciando usuarios internos y externos, incluyendo límites y canal de revisión.”
- “Diseña un ‘kit mínimo’ de explicabilidad para un caso de alto impacto (RRHH/finanzas): criterios, umbrales, logs, evidencias y procedimiento de revisión.”
- “Dame 10 ejemplos de explicaciones contrafactuales (qué tendría que cambiar) para un sistema de scoring, evitando proxies y siendo útil para el usuario.”

7.2.1 Dato personal y dato sensible: conceptos clave

Referencia

- **Módulo:** 7. Ética, privacidad y legislación aplicada a la IA
- **Apartado:** 7.2. Privacidad aplicada a IA: datos, trazabilidad y anonimización
- **Ficha:** 7.2.1 Dato personal y dato sensible: conceptos clave

Palabras clave

dato personal, dato sensible, RGPD, categorías especiales de datos, identificadores directos, identificadores indirectos, reidentificación, consentimiento, base jurídica, tratamiento de datos, responsable y encargado, datos de menores

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Explicar qué es un **dato personal** y reconocerlo incluso cuando no es “obvio” (identificación indirecta).
2. Diferenciar un dato personal “normal” de un **dato sensible** (categorías especiales) y entender por qué aumenta el riesgo.
3. Identificar **identificadores directos** e **indirectos** y el concepto de **reidentificación**.
4. Entender por qué “no poner el nombre” no equivale a “no tratar datos personales”.
5. Aplicar una regla práctica para el trabajo con IA: qué datos no deben entrar en prompts, cómo anonimizar y cuándo escalar a revisión.

Síntesis

En proyectos de IA (incluyendo chatbots, LLMs y automatizaciones), el riesgo principal no suele ser “la herramienta”, sino el uso de **datos personales** sin control. Un dato personal no es solo un nombre: puede ser cualquier información que identifique a alguien directa o indirectamente. Los **datos sensibles** (categorías especiales) elevan el riesgo y exigen aún más cuidado. Esta ficha te enseña a reconocer tipos de datos, identificar identificadores indirectos (proxies de identidad), entender reidentificación y aplicar reglas prácticas para usar IA de forma segura en empresa.

Contenido principal

1) Qué es un dato personal (explicación simple y útil)

Un **dato personal** es cualquier información que permite identificar a una persona física, **directamente o indirectamente**.

- **Directamente:** “María López”, “DNI 123...”, “marialopez@...”.
- **Indirectamente:** combinaciones que, juntas, señalan a una persona: “la directora de RRHH de la empresa X en Toledo”, “la única persona con ese cargo”, “cliente que compró el día tal y vive en tal zona”.

Idea clave: dato personal no es “un campo” concreto; es una propiedad del dato: si permite identificar a una persona, es personal.

2) Identificadores directos vs indirectos (y por qué importa en IA)

2.1 Identificadores directos

Son datos que por sí solos suelen identificar:

- nombre y apellidos,
- DNI/NIE/pasaporte,
- email personal,
- teléfono,
- dirección postal completa,
- número de seguridad social,
- número de empleado (en entornos internos).

Riesgo en IA: si se introducen en prompts o documentos compartidos, se pueden replicar en salidas, logs o historiales.

2.2 Identificadores indirectos (o cuasi-identificadores)

No identifican solos, pero combinados sí:

- edad + código postal + puesto,
- fecha de nacimiento + centro educativo,
- empresa + cargo + localidad,
- hábitos de compra muy específicos,
- combinación de metadatos (fechas, ubicaciones, patrones).

Por qué es crítico: mucha gente cree que “si quito el nombre ya está”. En realidad, la reidentificación suele ocurrir por combinaciones de indirectos.

3) Qué es un dato sensible (categorías especiales) y por qué es “más delicado”

Los **datos sensibles** (categorías especiales) son aquellos cuyo mal uso puede causar un daño mayor (discriminación, vulneración de derechos, estigmatización). Incluyen, de forma general:

- salud (diagnósticos, medicación, bajas),
- orientación sexual o vida sexual,
- origen racial o étnico,
- religión o creencias,
- afiliación sindical,
- datos biométricos usados para identificación,
- datos genéticos,
- opiniones políticas (en muchos contextos).

Idea clave: sensible no significa “secreto”, sino “alto impacto si se usa mal”.

En proyectos con IA, estos datos exigen:

- mayor justificación,
- más medidas técnicas y organizativas,
- y, a menudo, una limitación estricta de acceso y retención.

4) Datos de menores: por qué elevan aún más el riesgo

Los datos de menores requieren especial cuidado, porque la exposición o mal uso puede ser especialmente dañino. En práctica profesional, esto implica:

- minimización aún más estricta,
- controles de acceso fuertes,
- evitar usar datos reales de menores en pruebas o prompts,
- y procedimientos de revisión.

5) “Tratar datos” y “usar IA” son lo mismo a efectos de riesgo operativo

En empresa, **tratar datos** significa hacer cualquier cosa con ellos: recoger, almacenar, consultar, transformar, enviar, clasificar, resumir, etc.

Cuando pegas un texto con datos personales en un LLM, ya estás tratando datos. Aunque no “guardes” a propósito, puede haber:

- historiales,
- logs,
- copias en sistemas intermedios,
- o reuso en documentos.

Recomendación para el alumno: asume que todo lo que introduces en una herramienta puede persistir en algún sitio (historial, exportaciones, capturas, logs), y actúa con prudencia.

6) Regla práctica para usar IA sin meter la pata

Antes de usar IA con datos de empresa, aplica estas preguntas:

1. ¿Necesito realmente este dato personal para la tarea?
2. ¿Puedo reemplazarlo por un identificador interno o por un marcador?
3. ¿Estoy incluyendo datos sensibles? (si sí, parar y escalar)
4. ¿Qué pasaría si este texto se comparte fuera?
5. ¿Hay una alternativa: resumen sin datos, anonimización, o trabajo con datos ficticios?

Ejemplo de anonimización rápida en prompts

- Sustituye: nombre → [NOMBRE], email → [EMAIL], teléfono → [TEL], dirección → [DIRECCIÓN], pedido → [PEDIDO_ID].

7) Errores típicos (y cómo evitarlos)

- **Error 1:** “No pasa nada, es solo un ejemplo” → los ejemplos suelen acabar circulando.
- **Error 2:** pegar conversaciones completas de clientes → extrae solo lo imprescindible y anonimiza.
- **Error 3:** usar datos reales en demos → usa datos sintéticos (inventados) pero realistas.
- **Error 4:** guardar “por si acaso” → minimiza y define retención.

Relación de ideas clave

- Dato personal = cualquier dato que identifique directa o indirectamente.
- Quitar el nombre no siempre evita identificación (indirectos y reidentificación).
- Dato sensible eleva el riesgo y requiere controles más fuertes.
- En IA, introducir datos en prompts también es tratamiento de datos.
- Regla profesional: minimiza, anonimiza y escala en casos sensibles.

Más información en ChatGPT

- “Te doy este texto de un ticket: reescríbelo anonimizado manteniendo el sentido, sustituyendo datos personales por marcadores.”
- “Ayúdame a clasificar estos campos como: dato personal directo, indirecto, sensible o no personal: [lista].”

7.2.2 Principios de privacidad en IA: finalidad, minimización, retención y seguridad

Referencia

- **Módulo:** 7
- **Apartado:** 7.2 Privacidad aplicada a IA
- **Ficha:** 7.2.2 Principios de privacidad en IA: finalidad, minimización, retención y seguridad

Palabras clave

principios de privacidad, finalidad, minimización de datos, retención, seguridad, privacy by design, acceso por roles, cifrado, control de proveedores, evaluación de riesgos, tratamiento responsable

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Aplicar cuatro principios esenciales a proyectos de IA: **finalidad, minimización, retención y seguridad**.
2. Traducir esos principios a decisiones prácticas: qué datos pedir, cuánto guardar, quién accede y cómo se protege.
3. Diseñar un “mínimo viable” de privacidad: checklist, roles y medidas básicas para un proyecto con LLM/automatización.
4. Evitar errores típicos: recolectar de más, guardar indefinidamente, usar herramientas sin control y abrir accesos excesivos.

Síntesis

La privacidad en proyectos de IA no se resuelve con un aviso legal: se diseña desde el principio. Cuatro principios dan la base operativa: **finalidad** (para qué se usan los datos), **minimización** (usar solo lo imprescindible), **retención** (no guardar más tiempo del necesario) y **seguridad** (proteger acceso, transporte y almacenamiento). Esta ficha convierte esos principios en decisiones concretas para chatbots, automatizaciones y análisis con IA, con recomendaciones aplicables en pymes y empresas.

Contenido principal

1) Privacy by design: la idea que cambia todo

Privacy by design significa diseñar la privacidad “de serie”, no añadirla al final. En IA esto es crucial porque:

- la IA tiende a pedir mucho contexto,
- los equipos copian/pegan datos para “ayudar” al modelo,
- y los sistemas generan logs y trazas.

El enfoque correcto es preguntar:

“¿Cuál es el mínimo dato que necesito para alcanzar el objetivo con calidad?”

2) Finalidad: para qué se usan los datos (y por qué no vale “para mejorar”)

Finalidad significa que los datos se usan para un propósito concreto y legítimo.

En la práctica: definir exactamente qué hace el sistema.

Ejemplos de finalidad clara:

- “Clasificar tickets por motivo y prioridad”
- “Extraer campos de una factura para registro contable”
- “Responder FAQs usando documentos internos aprobados”

Ejemplo de finalidad mala:

- “Recopilar datos para mejorar” (demasiado vago, abre la puerta a usos no previstos).

Consejo operativo: cada campo de datos debería poder justificarse con una frase:

“Necesito este dato para X; sin él, no puedo hacer Y”.

3) Minimización: pedir lo mínimo y diseñar para no depender de datos sensibles

Minimización es el principio que más reduce riesgos, porque evita el problema antes de que aparezca.

3.1 Cómo se aplica en IA y automatización

- En un formulario: pide menos campos.
- En un chatbot: no solicites datos sensibles por chat; deriva a canal seguro.
- En prompts: no pegues conversaciones completas si basta con un resumen anonimizado.
- En bases de conocimiento: evita incluir datos personales en documentos que el asistente usará.

3.2 Técnica sencilla: “capas de datos”

- **Capa 1 (mínima):** dato imprescindible para resolver (ej. pedido_id).
- **Capa 2 (opcional):** mejora pero no bloquea (ej. comentario).
- **Capa 3 (sensible):** solo por canal seguro y con revisión.

Recomendación: si un caso requiere capa 3, el asistente debería escalar a humano o a formulario seguro.

4) Retención: cuánto tiempo se guardan datos y por qué

Retención es definir cuánto tiempo se guardan:

- logs,
- conversaciones,
- archivos,
- prompts,
- resultados.

En IA el riesgo típico es guardar “por si acaso”. Eso aumenta exposición.

4.1 Retención práctica (modelo simple)

- Datos operativos necesarios: retención limitada (ej. 30–90 días)
- Evidencias legales o contractuales: según normativa/proceso
- Datos de prueba: usar sintéticos y borrar al final

Consejo: retención debe tener propietario (quién decide) y rutina (cuándo se purga).

5) Seguridad: proteger acceso, tránsito y almacenamiento

Seguridad no es solo “tener contraseña”. Es un conjunto de controles:

5.1 Acceso por roles (mínimo privilegio)

Principio de **mínimo privilegio**: cada usuario accede a lo mínimo necesario.

- Un marketer no debería ver datos sensibles de clientes si no es imprescindible.
- Un proveedor externo no debería tener acceso completo a todos los registros.

5.2 Cifrado (explicación simple)

Cifrar es convertir datos en ilegibles para quien no tiene clave. Hay dos momentos:

- **en tránsito:** cuando viajan (HTTPS)
- **en reposo:** cuando están guardados (disco/base de datos)

5.3 Control de proveedores y herramientas

Si usas herramientas cloud, evalúa:

- dónde se almacenan datos,
- políticas de retención,
- accesos,
- y opciones de desactivar historiales o limitar uso.

Recomendación: lista de herramientas “aprobadas” y reglas claras de uso para el equipo.

6) Checklist mínimo de privacidad para un proyecto con IA (MVP)

1. Finalidad definida (1–2 frases)
2. Lista de datos necesarios (y por qué)
3. Datos sensibles: prohibidos en prompts/chat, canal alternativo
4. Retención definida (logs y conversaciones)
5. Accesos por rol (quién ve qué)
6. Registro de incidencias (qué hacer si hay fuga)
7. Revisión periódica (mensual/trimestral)

Relación de ideas clave

- Finalidad clara evita usos “inflados” de datos.
- Minimización reduce riesgo y mejora control.
- Retención evita acumular exposición.
- Seguridad = roles, cifrado, control de herramientas y proveedores.
- La privacidad se diseña, no se “añade”.

Más información en ChatGPT

- “Ayúdame a redactar la finalidad y la lista mínima de datos para este caso de uso: [describe caso].”
- “Propón una política de retención para logs y conversaciones de un chatbot interno/externo.”

7.2.3 Trazabilidad del dato: ciclo de vida, accesos y logs

Referencia

- **Módulo:** 7
- **Apartado:** 7.2 Privacidad aplicada a IA
- **Ficha:** 7.2.3 Trazabilidad del dato: ciclo de vida, accesos y logs

Palabras clave

trazabilidad del dato, ciclo de vida del dato, data lineage, accesos, logs, auditoría, control de cambios, registro de eventos, observabilidad, incident response, cadena de custodia

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Explicar qué es **trazabilidad del dato** y por qué es clave en proyectos de IA (auditoría, seguridad y calidad).
2. Describir el **ciclo de vida del dato** (captura → procesamiento → almacenamiento → uso → compartición → borrado).
3. Diseñar una estructura mínima de **logs** (qué registrar, qué no, cuánto tiempo, quién accede).
4. Entender cómo se gestionan **accesos** y por qué el control de permisos y el registro de accesos reduce riesgos.
5. Proponer un procedimiento básico ante incidencias: detección, contención, análisis y mejora.

Síntesis

Trazabilidad del dato significa poder responder: “¿de dónde salió este dato, quién lo tocó, dónde se guardó, cómo se transformó y quién lo vio?”. En IA esto es crítico porque hay múltiples pasos (automatizaciones, modelos, bases de conocimiento) y la falta de trazabilidad impide auditar, corregir errores o responder a incidentes. Esta ficha te enseña el ciclo de vida del dato, cómo diseñar logs mínimos y cómo gestionar accesos y evidencias sin guardar más información de la necesaria.

Contenido principal

1) Qué es trazabilidad del dato (en lenguaje de empresa)

Trazabilidad es **poder reconstruir la historia** de un dato:

- origen (fuente),
- transformaciones,
- destinos,
- accesos,
- y borrado.

En proyectos con IA, sin trazabilidad:

- no puedes demostrar cumplimiento,
- no puedes investigar errores,
- y no puedes mejorar con evidencia.

2) Ciclo de vida del dato (modelo completo)

2.1 Captura

Dónde entra el dato:

- formularios, CRM, email, chat, web, documentos.

Riesgo típico: capturar más de lo necesario.

Control: minimización desde el diseño.

2.2 Procesamiento

Qué haces con el dato:

- limpieza, clasificación, extracción, resumen, scoring.

Riesgo: el dato se copia a más lugares.

Control: registrar transformaciones y evitar duplicaciones.

2.3 Almacenamiento

Dónde se guarda:

- base de datos, drive, logs, herramientas externas.

Riesgo: retención indefinida y accesos amplios.

Control: política de retención y roles.

2.4 Uso

Quién lo usa y para qué:

- equipos, modelos, asistentes, reporting.

Riesgo: usos fuera de finalidad.

Control: finalidades definidas y auditoría.

2.5 Compartición

A quién sale:

- proveedores, integraciones, exportaciones.

Riesgo: fuga o exposición.

Control: contratos, límites de acceso, cifrado, mínimos datos.

2.6 Borrado/purga

Cuándo se elimina:

- por expiración, solicitud, política.

Riesgo: "se olvida" borrar o quedan copias.

Control: rutinas automáticas y verificación.

3) Logs: qué son y por qué son imprescindibles

Un **log** es un registro de eventos: "ocurrió X, a las Y, con Z".

En IA, logs permiten:

- auditar decisiones,
- detectar patrones anómalos,
- y depurar fallos.

Pero hay un equilibrio: logs son útiles, pero pueden contener datos personales si se registran mal.

4) Diseño de logs mínimos (sin pasarte)

4.1 Qué registrar (mínimo útil)

- identificador de ejecución (`trace_id`)
- fecha/hora
- fuente (`source`)
- acción (qué módulo/proceso)
- resultado (OK / revisión / error)
- códigos de error (si hay)
- IDs internos (no datos personales)

4.2 Qué NO registrar (por defecto)

- textos completos de clientes,
- datos sensibles,
- documentos enteros,
- prompts con información personal.

Si necesitas guardar evidencia, guarda un **resumen anonimizado** o referencias (IDs).

4.3 Retención de logs

Define:

- cuánto tiempo (ej. 30–90 días),
- quién puede acceder,
- cómo se purgan.

5) Accesos: permisos y “mínimo privilegio”

La trazabilidad no solo es del dato: es de **quién lo ve**.

Buenas prácticas:

- roles por necesidad (marketing, soporte, admin),
- revisiones periódicas de permisos,
- registro de accesos a datos sensibles,
- evitar “cuentas compartidas”.

Recomendación: si un dato es sensible, el acceso debe estar justificado, limitado y registrable.

6) Trazabilidad en IA generativa y asistentes

En asistentes con IA, la trazabilidad práctica incluye:

- versión del prompt/plantilla,
- fuentes consultadas (si hay base de conocimiento),
- decisión de escalado a humano,
- resumen del motivo (sin datos sensibles),
- registro de cambios en políticas/KB.

Esto permite responder ante preguntas como:

- “¿por qué el asistente dijo esto?”
- “¿qué documento usó?”
- “¿quién lo cambió y cuándo?”

7) Protocolo básico de incidentes (cuando algo sale mal)

1. Detectar (alerta, queja, anomalía)
2. Contener (limitar acceso, detener proceso)
3. Analizar (qué dato, qué ruta, quién accedió)
4. Corregir (política, permisos, logs, proceso)
5. Aprender (añadir test y revisión para que no se repita)

Relación de ideas clave

- Trazabilidad = historia del dato + accesos + transformaciones.
- Ciclo de vida ayuda a detectar dónde se multiplican riesgos.
- Logs deben ser útiles pero minimizados: registrar IDs y eventos, no datos sensibles.
- Control de accesos y registro de accesos reduce riesgos.
- Incidentes se gestionan con un protocolo simple y repetible.

Más información en ChatGPT

- “Diseña un esquema de logs mínimo para este flujo con IA: [describe flujo], evitando datos personales y proponiendo trace_id y campos.”
- “Crea un protocolo de respuesta a incidentes de datos para una pyme que usa chatbots y automatización.”

7.2.4 Anonimización vs seudonimización: diferencias y riesgo de reidentificación

Referencia

- **Módulo:** 7
- **Apartado:** 7.2 Privacidad aplicada a IA
- **Ficha:** 7.2.4 Anonimización vs seudonimización: diferencias y riesgo de reidentificación

Palabras clave

anonimización, seudonimización, reidentificación, k-anonimato, datos sintéticos, enmascaramiento, hashing, tokenización, riesgo residual, privacidad diferencial, combinación de datasets

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Diferenciar **anonimización** y **seudonimización** con ejemplos claros.
2. Entender que seudonimizar no elimina el carácter personal del dato: reduce riesgo pero no lo hace “anónimo”.
3. Identificar escenarios típicos de **reidentificación** (cruce de datasets, indirectos, datos raros).
4. Aplicar técnicas prácticas: enmascaramiento, generalización, tokenización, datos sintéticos (según caso).
5. Diseñar un procedimiento para preparar datos antes de usar IA: qué quitar, qué sustituir, qué agregar y cómo validar riesgo.

Síntesis

Anonimizar y seudonimizar no son lo mismo. La **anonimización** busca que una persona no pueda ser identificada de manera razonable; la **seudonimización** sustituye identificadores por tokens, pero la persona puede volver a identificarse si existe la “llave” o si se cruzan datos. En proyectos de IA, muchas fugas ocurren porque se confunde seudonimización con anonimización y se ignora la reidentificación por combinaciones de datos. Esta ficha enseña las diferencias, el riesgo real y un método práctico para preparar datos de forma segura.

Contenido principal

1) Anonimización: qué significa “no identificable” en la práctica

Anonimización significa transformar los datos de modo que ya no sea razonable identificar a la persona, incluso cruzando con información disponible (dentro de límites

razonables). No es una garantía absoluta en el universo, pero sí un objetivo: minimizar reidentificación de forma realista.

Técnicas típicas:

- eliminar identificadores directos,
- generalizar (edad → rango),
- agrupar (zona amplia en vez de dirección),
- eliminar outliers (casos únicos),
- reducir granularidad temporal (fecha exacta → mes),
- y revisar combinaciones.

Clave didáctica: anonimizar bien requiere pensar en combinaciones, no en un campo suelto.

2) Seudonimización: qué es y por qué sigue siendo dato personal

Seudonimización sustituye identificadores directos por un código o token:

- "María López" → "ID_4381"
- email → "TOKEN_92A..."

Pero si existe una tabla o mecanismo que permite volver atrás (la "llave"), o si el conjunto mantiene muchos indirectos, el dato sigue siendo personal.

Ventaja: reduce exposición (si se filtra, no se ve el nombre).

Límite: no elimina reidentificación, solo la dificulta.

3) Reidentificación: cómo ocurre en el mundo real

La **reidentificación** ocurre cuando alguien logra inferir quién es la persona a partir de:

- combinaciones de indirectos,
- cruce con otros datasets,
- o casos raros.

Escenarios típicos:

- "En la empresa hay una sola persona con ese cargo y edad aproximada."
- "Cruzo código postal + fecha + evento y lo identifico."
- "Un conjunto incluye un caso tan específico que es único."

Recomendación: si un registro es "único", es un riesgo. La anonimización debe tratar unicidad.

4) Técnicas prácticas (sin matemáticas complejas)

4.1 Enmascaramiento

Ocultar parte del dato:

- teléfono: 6 primeros dígitos ocultos
- email: "m***@dominio.com"

Útil para visualizar, no siempre suficiente para anonimizar.

4.2 Generalización

Reducir precisión:

- edad exacta → rango (20–29)

- dirección → provincia
- fecha exacta → mes

Muy útil para reducir reidentificación.

4.3 Tokenización / Hashing (explicación simple)

- **Tokenización:** reemplazar por token y guardar tabla segura de equivalencia.
- **Hashing:** transformar el dato mediante una función que produce un valor fijo (no reversible fácilmente), pero cuidado: si el espacio es pequeño (emails comunes), puede reidentificarse por diccionario.

Consejo: hashing no es “anonimización mágica”.

4.4 Datos sintéticos

Generar datos “inventados” que conservan patrones estadísticos sin corresponder a personas reales (según método). Útil para:

- demos,
- pruebas,
- entrenamiento básico (según contexto).

Recomendación: para entornos formativos, los datos sintéticos son la opción más segura.

5) Método para preparar datos antes de usar IA (checklist práctico)

1. Identificar campos personales directos
2. Identificar indirectos críticos (combinables)
3. Decidir: eliminar / generalizar / tokenizar
4. Revisar unicidad (¿hay casos raros?)
5. Revisar datos sensibles: idealmente excluirlos o tratarlos con controles extra
6. Probar reidentificación “de sentido común” (¿podría alguien del equipo adivinar quién es?)
7. Documentar la transformación y retención (cuánto guardo y dónde)

6) Error frecuente: “anonimicé” pero guardé el original en otro sitio

Una práctica peligrosa es:

- compartir dataset “anonimizado”,
- pero mantener el original accesible sin control.

Esto invalida el esfuerzo. La privacidad también es control de accesos.

7) Qué enfoque usar según objetivo (guía rápida)

- **Demos y formación:** datos sintéticos o anonimización fuerte.
- **Analítica interna:** seudonimización + control de acceso + retención.
- **Casos sensibles:** minimizar y, si procede, revisión legal/seguridad.

Relación de ideas clave

- Anonimización busca no identificar razonablemente; seudonimización reduce exposición pero sigue siendo dato personal.
- La reidentificación ocurre por combinaciones y cruces, no por un único campo.
- Técnicas útiles: generalización, eliminación de unicidad, tokenización y datos sintéticos.
- Preparar datos es un proceso: identificar, transformar, validar y documentar.
- Control de accesos y retención son parte de la privacidad, no solo la técnica.

Más información en ChatGPT

- “Dame un plan de anonimización para este dataset (campos): [lista], indicando qué eliminar, qué generalizar y qué tokenizar, y por qué.”
- “Reescribe este texto con datos personales eliminados o sustituidos por marcadores, manteniendo utilidad para análisis: [pega texto].”

7.5.1 RGPD: bases jurídicas para uso de datos en IA

Referencia

- **Módulo:** 7. Ética, privacidad y legislación aplicada a la IA
- **Apartado:** 7.5. Marco normativo aplicado: RGPD + Reglamento Europeo de IA
- **Ficha:** 7.5.1 RGPD: bases jurídicas para uso de datos en IA

Palabras clave

RGPD, base jurídica, licitud del tratamiento, artículo 6 RGPD, consentimiento, contrato, obligación legal, interés legítimo, finalidad, LLM, IA generativa, datos sensibles, artículo 9 RGPD, DPIA

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Explicar qué es una **base jurídica** y por qué es obligatoria para tratar datos personales, también en proyectos de IA.
2. Diferenciar las **6 bases jurídicas** del Art. 6 RGPD y reconocer cuándo suelen aplicar en contextos empresariales. (gdpr-info.eu)
3. Entender el riesgo de “elegir consentimiento por defecto” y cuándo suele ser mejor contrato u interés legítimo (según el caso). (edpb.europa.eu)
4. Identificar el “doble escalón” cuando hay **datos sensibles** (además de Art. 6, se requiere condición adicional). (Homepage | Data Protection Commission)
5. Traducir lo legal a una decisión operativa: qué datos usar, cómo minimizarlos, y qué controles aplicar (retención, acceso, trazabilidad).

Síntesis

En RGPD, no basta con “tener cuidado”: para tratar datos personales necesitas una **base jurídica** (Art. 6). (gdpr-info.eu) En proyectos de IA, el riesgo típico es usar datos “porque están disponibles” sin justificar el porqué. Esta ficha explica las bases jurídicas más frecuentes en empresa (contrato, interés legítimo, consentimiento, obligación legal), cómo elegir con criterio y cómo aterrizar esa elección en el diseño del sistema (minimización, retención, seguridad, trazabilidad). También aclara el caso de **datos sensibles**, donde se necesita un requisito adicional (Art. 9). (Homepage | Data Protection Commission)

Contenido principal

1) Qué es una base jurídica y por qué importa en IA

La **base jurídica** es la razón legal que hace lícito el tratamiento de datos personales. En RGPD, el tratamiento solo es lawful si encaja en al menos una de las bases del Art. 6. (gdpr-info.eu)

En IA, tratar datos incluye: capturar, clasificar, resumir, analizar, almacenar en logs, enviar

a un proveedor, etc. Por eso, un “prompt” con datos personales también puede ser tratamiento, y debe estar justificado.

Consejo mental para el alumno: la base jurídica no es un “papel”. Es un filtro: define **qué puedes hacer** y **qué no** con los datos.

2) Las 6 bases jurídicas del Art. 6 RGPD (en lenguaje de empresa)

El Art. 6 incluye seis bases: consentimiento, contrato, obligación legal, intereses vitales, misión de interés público/autoridad pública, e interés legítimo. (gdpr-info.eu)

En empresa, las más comunes suelen ser:

2.1 Contrato (o medidas precontractuales)

Aplica cuando el tratamiento es necesario para prestar un servicio, gestionar una compra, una reserva o un acuerdo con el usuario/cliente.

Ejemplos:

- gestionar un pedido (datos de envío),
- atender una incidencia del servicio,
- preparar una propuesta solicitada.

Riesgo típico: meter datos extra “para mejorar IA” que no son necesarios para el contrato.

Recomendación: separa “operación del servicio” de “mejora/modelo”. Lo primero puede estar cubierto por contrato; lo segundo exige análisis adicional y minimización fuerte.

2.2 Interés legítimo

Es muy común en empresa, pero exige justificarlo (test de ponderación: interés real vs derechos del usuario). El EDPB recalca que no debe usarse como “último recurso” ni automáticamente: requiere condiciones acumulativas. (edpb.europa.eu)

Ejemplos habituales:

- seguridad (detección de abuso/fraude),
- mejora de servicio con analítica agregada,
- ciertas comunicaciones internas B2B.

Riesgo típico en IA: “interés legítimo” para entrenar o alimentar un sistema con datos personales sin controles.

Recomendación práctica: si usas interés legítimo, documenta:

- qué interés persigues,
- por qué es necesario,
- y qué garantías aplicas (minimización, retención, opt-out, revisión humana en alto impacto).

2.3 Consentimiento

El consentimiento debe ser libre, informado, específico y revocable. Por eso, en empresa no siempre es la mejor base (por ejemplo, si hay desequilibrio).

Ejemplos:

- newsletter,
- personalización opcional,
- uso voluntario de datos para fines adicionales.

Riesgo típico: pedir consentimiento “por si acaso” y luego usarlo para todo.

Recomendación: si la finalidad es necesaria para prestar el servicio, normalmente no uses consentimiento; usa contrato (si procede). Si la finalidad es adicional, ahí sí puede encajar.

2.4 Obligación legal

Cuando la empresa debe tratar datos para cumplir una norma.

Ejemplos:

- obligaciones fiscales/contables,
- registros exigidos por ley.

Recomendación: no mezclar obligación legal con usos de IA “creativos”. La obligación legal cubre el cumplimiento, no el uso extra no necesario.

3) El caso especial: datos sensibles (Art. 9) y el “doble requisito”

Si hay **categorías especiales** (salud, biométricos, etc.), además de Art. 6 necesitas cumplir una condición adicional (Art. 9), tal como recuerdan autoridades de protección de datos. ([Homepage | Data Protection Commission](#))

En práctica de IA:

- evita usar datos sensibles en prompts o datasets salvo necesidad clara,
- usa canales seguros,
- limita acceso,
- y suele requerir evaluación de impacto (DPIA) en muchos casos.

4) Cómo elegir base jurídica en proyectos con IA (método práctico)

1. Define la **finalidad** exacta (qué hace el sistema).
2. Lista datos mínimos necesarios.
3. Elige base jurídica para esa finalidad (no para “todo”). ([gdpr-info.eu](#))
4. Si hay datos sensibles: revisa Art. 9 (doble requisito). ([Homepage | Data Protection Commission](#))
5. Define garantías: minimización, retención, seguridad, trazabilidad, revisión humana.

Checklist rápido

- ¿La IA toma decisiones de alto impacto? → más controles y posible revisión jurídica.
- ¿Usas interés legítimo? → documenta test y opt-out cuando aplique. ([edpb.europa.eu](#))
- ¿Usas consentimiento? → asegúrate de que sea revocable sin penalización.

Relación de ideas clave

- RGPD exige una base jurídica (Art. 6) para tratar datos personales. ([gdpr-info.eu](#))
- En empresa, las más habituales: contrato, interés legítimo y consentimiento (con cautela). ([edpb.europa.eu](#))

Programa Superior en Inteligencia Artificial Aplicada a la Empresa

Fichas de contenido

- Con datos sensibles hay doble requisito (Art. 6 + condición Art. 9). ([Homepage | Data Protection Commission](#))
- La base jurídica debe aterrizar en diseño: minimización, retención, seguridad y trazabilidad.

Más información en ChatGPT

- “Para este caso de uso con IA: [describe], propón base jurídica probable, datos mínimos, riesgos y garantías (minimización/retención/seguridad/opt-out).”
- “Ayúdame a redactar un ‘test de interés legítimo’ simplificado para este tratamiento: [describe].” ([edpb.europa.eu](#))

7.5.2 RGPD: deber de informar y transparencia con usuarios

Referencia

- **Módulo:** 7
- **Apartado:** 7.5
- **Ficha:** 7.5.2 RGPD: deber de informar y transparencia con usuarios

Palabras clave

deber de informar, transparencia, artículos 12–14 RGPD, política de privacidad, aviso de IA, finalidades, base jurídica, destinatarios, transferencias, plazos de conservación, decisiones automatizadas, perfilado

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Explicar qué significa el **derecho a ser informado** y por qué es clave para confianza y cumplimiento. ([Homepage | Data Protection Commission](#))
2. Identificar qué información debe incluir un aviso de privacidad (quién, para qué, base, destinatarios, retención, derechos...). ([Homepage | Data Protection Commission](#))
3. Diseñar mensajes de transparencia adaptados a IA: chatbots, formularios con IA, scoring, personalización.
4. Evitar errores típicos: avisos largos incomprensibles, falta de información sobre automatización, o avisos que no coinciden con la realidad del sistema.

Síntesis

El RGPD exige que el tratamiento sea transparente y que las personas sean informadas de forma clara y accesible (Art. 12–14). ([Homepage | Data Protection Commission](#)) En proyectos de IA, esta obligación se vuelve especialmente relevante: un usuario debe saber si interactúa con un sistema automatizado, qué datos se usan, con qué finalidad, y cómo ejercer sus derechos. Esta ficha enseña a construir avisos prácticos (no solo legales) y a integrar la transparencia en la experiencia (microcopies, mensajes del bot, y rutas de revisión).

Contenido principal

1) Transparencia: el principio que evita el “uso oculto” de IA

El RGPD insiste en que el tratamiento sea claro y transparente para los interesados. ([Homepage | Data Protection Commission](#))

En IA, el riesgo no es solo legal: es reputacional. Si un usuario descubre que “le evaluó un algoritmo” sin saberlo, la confianza cae incluso aunque el sistema funcionara bien.

2) Qué debe comunicar un aviso (checklist operativo)

Un aviso eficaz responde, como mínimo:

- **Quién** trata los datos (responsable).
- **Para qué** (finalidades).
- **Con qué base jurídica**.
- **Qué datos** se tratan (categorías).
- **A quién** se comunican (destinatarios/proveedores).
- **Cuánto tiempo** se conservan (retención).
- **Qué derechos** tiene el usuario y cómo ejercerlos. ([Homepage | Data Protection Commission](#))
- Si hay **decisiones automatizadas/perfilado** y qué implica (cuando aplique). ([gdpr-info.eu](#))

Consejo: la transparencia útil se escribe para una persona real, no para un abogado. Mantén claridad y estructura.

3) Transparencia específica cuando hay IA

3.1 Chatbots y asistentes

Incluye:

- “Estás interactuando con un asistente automatizado.” (transparencia de canal)
- “Qué puede hacer / qué no puede hacer.”
- “Qué datos no debes compartir.”
- “Cuándo deriva a un humano.”

3.2 Personalización y segmentación

Explica:

- qué señales se usan (a alto nivel),
- qué impacto tiene (p. ej., qué contenidos o emails recibes),
- opción de **oponerte** o ajustar preferencias cuando corresponda. ([edpb.europa.eu](#))

3.3 Scoring y decisiones con efecto relevante

Si un sistema decide o influye fuertemente (acceso, priorización, rechazos), la transparencia debe incluir:

- criterio general,
- canal de revisión,
- y cómo ejercer derechos.

4) Cómo integrar la transparencia en la UX (no solo en “política”)

- Aviso corto cerca del formulario (“Usaremos tus datos para...”)
- En chatbot: mensaje inicial fijo + recordatorios cuando se pidan datos
- En emails: enlace claro y lenguaje comprensible
- En panel de usuario: preferencias y trazabilidad (si existe)

Recomendación: “capas”: un resumen corto + enlace a detalle.

Relación de ideas clave

- RGPD exige transparencia y derecho a ser informado (Art. 12–14). ([Homepage | Data Protection Commission](#))
- En IA, la transparencia debe ser también UX: mensajes, límites, datos y escalado.
- Si hay automatización relevante, informa y ofrece revisión/canales.

Más información en ChatGPT

- “Redacta un aviso de privacidad por capas (resumen + detalle) para un chatbot de atención al cliente que usa IA, incluyendo límites y datos prohibidos.” ([Homepage | Data Protection Commission](#))
- “Convierte este texto legal largo en un aviso claro y entendible, manteniendo la información obligatoria: [pega texto].”

7.5.3 RGPD: derechos del interesado (acceso, supresión, oposición, etc.)

Referencia

- **Módulo:** 7
- **Apartado:** 7.5
- **Ficha:** 7.5.3 RGPD: derechos del interesado (acceso, supresión, oposición, etc.)

Palabras clave

derechos RGPD, acceso, rectificación, supresión, limitación, portabilidad, oposición, decisión automatizada, perfilado, reclamación, EDPB, DSAR

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Enumerar los derechos principales del RGPD y explicar qué significan en la práctica. (edpb.europa.eu)
2. Entender cómo afectan estos derechos a sistemas con IA (logs, historiales, datasets, modelos, proveedores).
3. Diseñar un flujo interno de respuesta a solicitudes (DSAR): recepción, verificación, búsqueda, respuesta, registro.
4. Identificar riesgos: no localizar datos por falta de trazabilidad, conservar más de la cuenta, o no poder justificar automatizaciones.

Síntesis

El RGPD otorga a las personas derechos sobre sus datos: saber qué se trata, corregir, borrar, oponerse, etc. (edpb.europa.eu) En IA, estos derechos exigen disciplina: trazabilidad del dato, políticas de retención, y control de proveedores. Esta ficha explica cada derecho de forma práctica y cómo preparar un proyecto con IA para responder solicitudes sin caos (dónde buscar, qué entregar, cómo registrar).

Contenido principal

1) Derechos principales (visión práctica)

El RGPD reconoce varios derechos; entre los más usados en empresa están:

- **Acceso:** confirmar si se tratan datos y acceder a ellos + información asociada. (gdpr-info.eu)
- **Rectificación:** corregir datos inexactos. (edpb.europa.eu)
- **Supresión** ("derecho al olvido"): borrar cuando proceda. (edpb.europa.eu)
- **Limitación:** "congela" el tratamiento en ciertos casos. (edpb.europa.eu)
- **Portabilidad:** recibir datos en formato reutilizable (cuando aplique). (edpb.europa.eu)

- **Oposición:** oponerse a ciertos tratamientos (p. ej., marketing o interés legítimo). (edpb.europa.eu)
- **Decisiones automatizadas/perfilado:** en algunos supuestos, derecho a información significativa sobre la lógica y consecuencias. (gdpr-info.eu)

Consejo: el derecho no es “teórico”: la empresa debe tener un procedimiento y un “mapa” de dónde está el dato.

2) El impacto en IA: dónde se esconden los datos

En proyectos con IA, los datos pueden estar en:

- CRM, helpdesk, formularios
- historiales de chat
- logs de automatización (trace_id)
- repositorios de documentos (base de conocimiento)
- exports y backups
- proveedores (herramientas cloud)

Riesgo: si no hay trazabilidad y retención clara, responder un acceso o supresión es difícil.

3) Procedimiento DSAR (flujo recomendado)

1. Recepción de solicitud (canal claro)
2. Verificación de identidad (sin pedir más de la cuenta)
3. Localizar datos (mapa de sistemas)
4. Extraer y revisar (evitar incluir datos de terceros)
5. Responder dentro de plazo y registrar
6. Ejecutar cambios (borrado/rectificación) y confirmar

Recomendación: documenta dónde se busca, y usa IDs internos para localizar sin exponer datos.

Relación de ideas clave

- Los derechos del interesado son operativos: hay que poder localizar y actuar. (edpb.europa.eu)
- IA amplía superficies: logs, historiales y proveedores.
- Trazabilidad + retención + mapa de sistemas facilitan cumplimiento.

Más información en ChatGPT

- “Diseña un procedimiento DSAR para una pyme con CRM + chatbot + automatizaciones: roles, pasos, checklist de respuesta y registro.” (gdpr-info.eu)
- “Crea un ‘mapa de sistemas’ para localizar datos personales en este stack: [lista herramientas].”

7.5.4 Reglamento Europeo de IA: enfoque por riesgo y obligaciones prácticas

Referencia

- **Módulo:** 7
- **Apartado:** 7.5
- **Ficha:** 7.5.4 Reglamento Europeo de IA: enfoque por riesgo y obligaciones prácticas

Palabras clave

EU AI Act, Reglamento Europeo de IA, enfoque por riesgo, prácticas prohibidas, alto riesgo, transparencia, obligaciones proveedor y deployer, gestión de riesgos, supervisión humana, logging, robustez, ciberseguridad, alfabetización en IA

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Explicar el **enfoque por riesgo** del AI Act: prohibido (inaceptable), alto riesgo, riesgo limitado (transparencia) y riesgo mínimo. (artificialintelligenceact.eu)
2. Identificar obligaciones prácticas típicas en alto riesgo: gestión de riesgos, datos/gobernanza, documentación, logs, supervisión humana, robustez y ciberseguridad (visión operativa). (legalnodes.com)
3. Aplicar una metodología de clasificación inicial para un caso de uso empresarial (asistente, scoring, selección, biometría, etc.).
4. Distinguir responsabilidades de **proveedor** (provider) y **usuario/implantador** (deployer) cuando se usa un sistema de terceros.

Síntesis

El Reglamento Europeo de IA adopta un modelo por niveles de riesgo: prohíbe ciertas prácticas por considerarlas inaceptables y establece obligaciones más fuertes para sistemas de alto riesgo; además, para sistemas de riesgo limitado impone obligaciones de transparencia (por ejemplo, informar cuando se interactúa con IA). (artificialintelligenceact.eu) Esta ficha traduce el enfoque a lenguaje de empresa: cómo clasificar casos, qué obligaciones suelen aparecer (gestión de riesgos, supervisión humana, logging, documentación) y cómo organizar el cumplimiento en proyectos reales.

Contenido principal

1) Enfoque por riesgo: la idea central

El AI Act no trata igual a todos los sistemas. Distingue categorías, y cuanto mayor el riesgo para derechos y seguridad, mayores las exigencias. Una síntesis habitual habla de:

- **Riesgo inaceptable (prohibido)**
- **Alto riesgo** (exigencias fuertes)
- **Riesgo limitado** (principalmente transparencia)
- **Riesgo mínimo** (sin obligaciones específicas relevantes, salvo buenas prácticas). (artificialintelligenceact.eu)

Consejo para alumno: el primer trabajo profesional es **clasificar el caso de uso**. No se puede diseñar cumplimiento sin clasificación.

2) Prohibiciones y alto riesgo (visión práctica)

La Comisión Europea ha publicado guías sobre prácticas prohibidas en el marco del AI Act. (digital-strategy.ec.europa.eu)

En alto riesgo, fuentes de síntesis señalan obligaciones a lo largo del ciclo de vida: gestión de riesgos, gobernanza de datos, documentación técnica, logging, supervisión humana, y requisitos de precisión/robustez/ciberseguridad. (legalnodes.com)

Traducción operativa (lo que cambia en un proyecto):

- no basta con “que funcione”: hay que **demostrar** controles, registros, y gobierno.

3) Transparencia (riesgo limitado) y ejemplos típicos

En riesgo limitado, hay obligaciones de transparencia: informar, por ejemplo, cuando un usuario interactúa con IA (chatbots) o cuando hay contenido sintético en ciertos contextos. (artificialintelligenceact.eu)

Aplicación práctica: en un asistente virtual:

- mensaje inicial claro,
- límites,
- canal de humano,
- y trazabilidad de fuentes si se usa base documental.

4) Proveedor vs deployer: responsabilidades cuando compras herramientas

- **Proveedor:** quien desarrolla/pone en el mercado.
- **Deployer** (usuario/implantador): quien lo usa en su organización/proceso.

En empresa, aunque el proveedor tenga obligaciones, el deployer debe:

- evaluar el caso,
- configurar bien (datos, accesos, límites),
- operar con supervisión,
- y documentar uso real.

Consejo: “lo compré” no te exime de diseñar controles y de formar al equipo.

Relación de ideas clave

- Al Act = enfoque por riesgo; clasificar el caso es el primer paso. (artificialintelligenceact.eu)

Programa Superior en Inteligencia Artificial Aplicada a la Empresa

Fichas de contenido

- Alto riesgo implica controles y documentación a lo largo del ciclo de vida. (legalnodes.com)
- Riesgo limitado enfatiza transparencia (p. ej., chatbots). (artificialintelligenceact.eu)
- Proveedor y deployer comparten responsabilidades: el uso real importa.

Más información en ChatGPT

- "Clasifica este caso de uso según enfoque por riesgo del AI Act y dime qué controles mínimos debería implementar la empresa: [describe caso]." (artificialintelligenceact.eu)
- "Crea un checklist de alto riesgo (gestión riesgos, logs, supervisión humana, robustez, documentación) adaptado a [caso]." (legalnodes.com)

7.5.5 Documentación y due diligence de proveedores: cumplimiento práctico

Referencia

- **Módulo:** 7
- **Apartado:** 7.5
- **Ficha:** 7.5.5 Documentación y due diligence de proveedores: cumplimiento práctico

Palabras clave

due diligence, proveedores IA, evaluación de proveedores, DPA, encargado del tratamiento, subencargados, transferencias internacionales, seguridad, ISO 27001, retención, logs, auditoría, SLA, documentación técnica

Objetivos de aprendizaje

Al finalizar la lectura, deberás ser capaz de:

1. Entender qué es **due diligence** de proveedores y por qué es crucial al usar herramientas de IA/LLM.
2. Preparar un checklist de evaluación: privacidad, seguridad, retención, subprocesadores, ubicación de datos, controles de acceso, logs y soporte.
3. Diferenciar documentación contractual y técnica: DPA, SLA, políticas, y “evidencias” de control.
4. Diseñar un paquete mínimo interno de documentación del proyecto (finalidad, datos, accesos, retención, riesgos, mitigaciones).

Síntesis

La mayoría de proyectos de IA en empresa se hacen con proveedores (SaaS, APIs, plataformas). El riesgo no está solo en el modelo: está en **cómo el proveedor trata datos**, qué retención aplica, qué subencargados usa y qué controles de seguridad ofrece. Esta ficha ofrece un método de due diligence práctico: qué preguntar, qué documentos pedir, qué decisiones dejar por escrito y cómo mantener un “expediente” del proveedor y del caso de uso.

Contenido principal

1) Por qué due diligence es imprescindible con IA

Con IA se incrementa la superficie:

- más datos pasan por más sistemas,
- hay logs,
- hay integraciones,
- y hay riesgo de uso fuera de finalidad.

Sin due diligence, puedes acabar:

- usando un proveedor con retención incompatible,
- sin control de accesos,
- o con subprocesadores no conocidos.

2) Checklist de evaluación del proveedor (práctico)

Privacidad

- ¿Qué datos se procesan y para qué finalidades?
- ¿Hay opciones para desactivar historiales/retención?
- ¿Qué subencargados existen?
- ¿Dónde se alojan datos (regiones)?
- ¿Hay transferencias internacionales y cómo se gestionan?

Seguridad

- Acceso por roles, MFA, cifrado en tránsito y reposo
- Registros/auditoría de acceso
- Gestión de incidentes y tiempos de notificación
- Buenas prácticas/certificaciones si existen (p. ej., ISO 27001)

Operación

- SLA (disponibilidad), soporte, backups
- Versionado de cambios
- Controles para entornos (dev/prod)

IA específica

- Controles anti-fugas, políticas de uso de datos para entrenamiento
- Opciones de “no training” si aplica
- Trazabilidad de fuentes (si hay RAG/KB)
- Controles de seguridad contra prompt injection (cuando aplique)

3) Documentación interna mínima del caso de uso (lo que debes guardar)

- Finalidad y base jurídica (RGPD) (gdpr-info.eu)
- Categorías de datos y minimización
- Retención (logs, conversaciones)
- Accesos por rol y responsables
- Riesgos y mitigaciones (incl. escalado a humano)
- Procedimiento de derechos (DSAR) (gdpr-info.eu)
- Clasificación de riesgo (AI Act) y controles asociados (artificialintelligenceact.eu)

Consejo: la documentación no es burocracia: es lo que te salva cuando hay auditoría, incidente o cambio de proveedor.

4) Señales de “buen proveedor” vs “riesgo”

Buenas señales

- transparencia de retención y subprocesadores
- controles de acceso y logs claros

Programa Superior en Inteligencia Artificial Aplicada a la Empresa

Fichas de contenido

- opciones de configuración de privacidad
- documentación y soporte

Señales de riesgo

- respuestas vagas (“cumplimos todo”) sin evidencias
- retención indefinida por defecto
- falta de claridad sobre subprocesadores
- imposibilidad de exportar o borrar datos

Relación de ideas clave

- IA en empresa suele implicar proveedores: evaluar proveedor es parte del cumplimiento.
- Due diligence cubre privacidad, seguridad, operación y aspectos IA.
- Mantén expediente del caso: finalidad, datos, retención, accesos, riesgos y procedimientos. (gdpr-info.eu)
- Un proveedor “opaco” es un riesgo operativo y reputacional.

Más información en ChatGPT

- “Crea un checklist de due diligence para evaluar un proveedor de IA/LLM en una pyme (privacidad, seguridad, retención, subprocesadores, logs, SLA).”
- “Ayúdame a redactar un ‘expediente de cumplimiento’ de 1–2 páginas para este caso de uso con IA: [describe], incluyendo RGPD + AI Act y controles.”